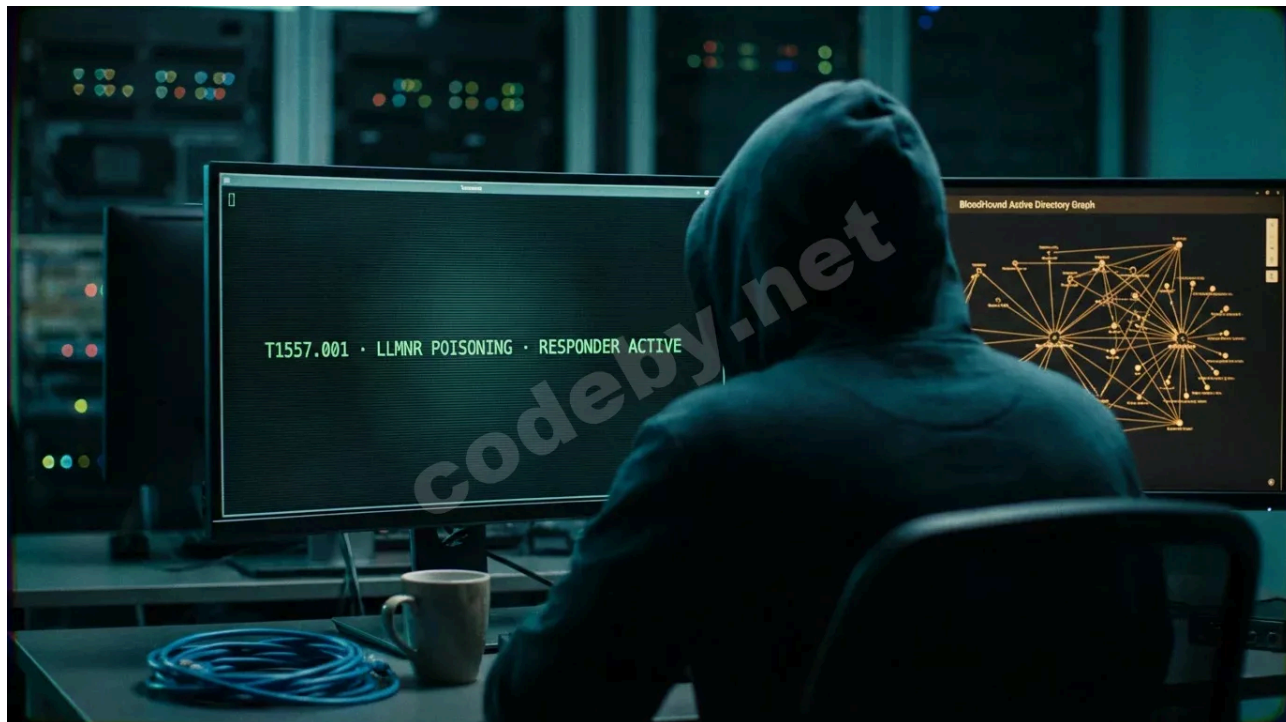


(30) Аудит Active Directory безопасность: чеклист за день

 codeby.net/threads/audit-active-directory-bezopasnost-laps-llmnr-i-logirovaniya-za-odin-rabochii-den.92854

Архип Борисов

April 27, 2026



Что атакующий видит в первые два часа в вашей сети

На каждом втором внутреннем пентесте - одна и та же картина: LLMNR включён по умолчанию, LAPS либо не развёрнут, либо покрывает только рабочие станции, а расширенный аудит Kerberos не настроен. Три проблемы, которые дают атакующему перехватить хеши (подробнее о механике - в [обзоре атак на аутентификацию Kerberos и identity-инфраструктуру](#)), вытянуть пароль локального администратора и двигаться по сети, не оставляя следов в логах. И всё это - в первые пару часов после попадания в периметр.

Это не теоретический обзор угроз. Это конкретный план действий, который пентестер или инженер ИБ пройдёт за один рабочий день: проверить состояние LLMNR/NBT-NS, убедиться в корректности развёртывания LAPS и настроить логирование так, чтобы blue team видела атаки, а не только стандартные логины. Всё - штатными средствами Windows, без покупки дорогих решений.

Аудит Active Directory безопасность - не проект на полгода с выделенным бюджетом. Большинство критических мiskonfigurations проверяются за часы, а закрываются за дни. Покажу, куда именно смотреть и какие команды запускать - опираясь на реальную практику внутренних пентестов и данные первоисточников.

Русскоязычные руководства по аудиту AD обычно сводятся к перечислению Event ID и описанию GPO-политик в вакууме. Здесь всё иначе: каждая рекомендация привязана к конкретной атаке - вот что делает атакующий, вот как это выглядит в логах, вот как проверить и закрыть за минуты.

LLMNR poisoning атака: почему Responder работает в большинстве сетей

Механика LLMNR poisoning и роль Responder в AD

Когда пользователь обращается к сетевому ресурсу, Windows проходит цепочку разрешения имён. Сначала проверяет DNS-клиентский кеш (включая записи из файла hosts, которые загружаются в кеш), затем шлёт DNS-запрос к серверу. И только если DNS не может разрешить имя - включается LLMNR (Link-Local Multicast Name Resolution) на UDP-порт 5355, а за ним NBT-NS (NetBIOS Name Service) на UDP-порт 137. Эта последовательность описана в документации Microsoft и стабильно воспроизводится на практике.

Проблема: LLMNR и NBT-NS работают через широковещательные запросы в локальной сети. Любой хост в сегменте может ответить на такой запрос. И ни один из этих протоколов не имеет механизма аутентификации ответов. По данным TCM Security, отсутствие аутентификации - причина, по которой LLMNR остаётся одним из самых надёжных начальных векторов при пентесте AD.

На практике выглядит так: пользователь допускает опечатку в UNC-пути (например, \\DCC01 вместо \\DC01), DNS не может разрешить несуществующее имя, Windows отправляет LLMNR-запрос мультикастом. Атакующий с запущенным Responder отвечает: «Это я, подключайся». Жертва шлёт NTLM-хеш для аутентификации - и NetNTLMv2-хеш уже у атакующего, готовый к офлайн-бруту. В материалах HackTheBox по детектированию LLMNR-атак разбирают конкретный PCAP, где виден весь цикл: опечатка → LLMNR-запрос → ответ от Kali-машины → утечка хеша.

```
[*] [LLMNR] Poisoned answer sent to 192.168.100.101 for name fielshare
[SMB] NTLMv2-SSP Client      : 192.168.100.101    TCP     Seq=880 Ack=1152 Win=32512 Len=0
[SMB] NTLMv2-SSP Username    : AIUK\user2        TCP     Seq=880 Ack=1152 Win=32512 Len=0
[SMB] NTLMv2-SSP Hash       : user2::AIUK:1122334455667788:B48729A91322323BD4283DD8C4A4F267:01010000
00000000009F8506E2C4BCD101F5B6DBEBD68390A90000000002000A0073006D0062003100320001001400530045005200
56004500520032003000300038000400160073006D006200310032002E006C006F00630061006C00003002C00530045005
20056004500520032003000300038002E0073006D006200310032002E006C006F00630061006C0000000160073006D0062
00310032002E006C006F00630061006C000080030003000000000000000000000000000020000043BD1E3E6C201D3D989B389
B5952622F2CDF272A83DDD0084F2145B78F2119930A00100000000000000000000000000000000000000000000000000000
660073002F006600690065006C00730068006100720065000000000000000000000000000000000000000000000000000
[SMB] Requested Share      : \\FIELSHARE\IPC$
[*] [LLMNR] Poisoned answer sent to 192.168.100.101 for name fielshare
[*] Skipping previously captured hash for AIUK\user2
[SMB] Requested Share      : \\FIELSHARE\IPC$
```

По классификации MITRE ATT&CK это техника [LLMNR/NBT-NS Poisoning and SMB Relay](#) (T1557.001), тактики Credential Access и Collection.

Запуск атаки тривиален: `sudo responder -I eth0 -dwP` поднимает LLMNR/NBT-NS-отравитель с WPAD-прокси. После перехвата хеша атакующий забирает его в Hashcat: `hashcat -m 5600 hashes.txt wordlist.txt` (модуль 5600 - NetNTLMv2). Если парольная политика слабая - пароль вскрывается за минуты. По данным TCM Security, пароли типа «Password1» ломаются мгновенно.

Со стороны жертвы ничего подозрительного - ресурс «не открылся», пользователь исправляет опечатку и работает дальше. А хеш уже у атакующего. Именно поэтому Responder AD атака - стандартный первый шаг при внутреннем пентесте. Я ни разу не видел сеть, где Responder не собрал бы хотя бы пару хешей за первые 20 минут (если, конечно, LLMNR не отключён).

Как проверить и отключить LLMNR и NBT-NS

Требования к окружению: доступ к Group Policy Management Console (GPMC), права на редактирование GPO уровня домена или OU, PowerShell 5.1+ на целевых хостах.

Первый шаг - убедиться в текущем состоянии. На любом хосте в домене:

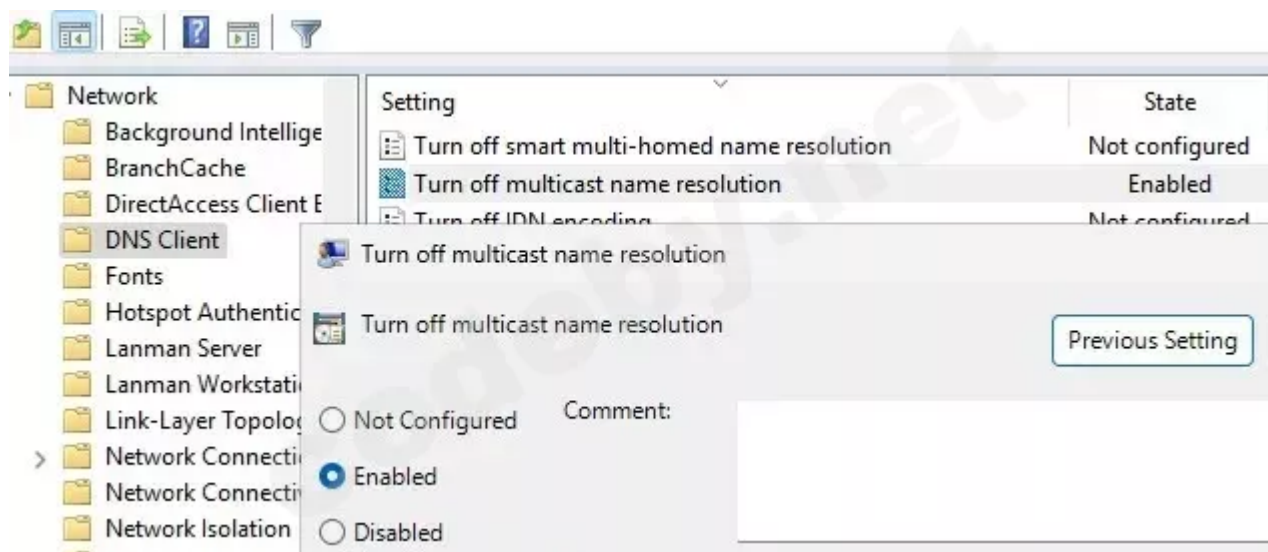
Код:

```
# Проверка LLMNR (0 = отключён, отсутствие ключа = включён)
```

```
Get-ItemProperty -Path "HKLM:\Software\Policies\Microsoft\Windows NT\DNSClient" `
    -Name EnableMulticast -ErrorAction SilentlyContinue
```

```
# Проверка NBT-NS (2 = отключён, 0 или 1 = активен)
```

```
wmic nicconfig get caption,index,TcpipNetbiosOptions
```



Если ключ `EnableMulticast` отсутствует или равен 1 - LLMNR активен. Если

TcpipNetbiosOptions возвращает 0 или 1 - NBT-NS активен. В обоих случаях сеть открыта для Responder.

Отключение LLMNR - через GPO: Computer Configuration > Administrative Templates > Network > DNS Client, параметр «Turn OFF Multicast Name Resolution» - установить в «Enabled». Основная рекомендация, подтверждённая TCM Security и HackTheBox.

Для NBT-NS встроенного параметра GPO нет. Используют PowerShell-скрипт в Startup Scripts (Computer Configuration > Policies > Windows Settings > Scripts > Startup):

```
Set-ItemProperty -Path  
HKLM:\SYSTEM\CurrentControlSet\services\NetBT\Parameters\Interfaces\tcpip* -  
Name NetbiosOptions -Value 2
```

После применения политик - `groupdate /force` на целевых хостах и повторная проверка. Значение `EnableMulticast = 0` и `TcpipNetbiosOptions = 2` подтверждают успешное отключение. Чтобы убедиться окончательно, запустите Responder в режиме анализа (без флага -P) и проверьте, что хеши больше не прилетают.

LAPS пентест: слабости, которые атакующий находит первыми

Проверка развёртывания LAPS при аудите Active Directory

LAPS (Local Administrator Password Solution) решает конкретную проблему: одинаковый пароль локального администратора на всех машинах домена. Без LAPS компрометация одного хоста означает доступ ко всем остальным через Pass-the-Hash - один хеш открывает lateral movement по всей сети.

Legacy LAPS генерирует уникальный пароль для каждого компьютера и хранит его в атрибутах объекта компьютера в AD: `ms-mcs-AdmPwd` (пароль в открытом тексте, доступный только субъектам с правом `CONTROL_ACCESS` / All Extended Rights на OU - обычно Domain Admins и явно делегированные группы) и `ms-mcs-AdmPwdExpirationTime` (время истечения). С 2023 года Microsoft выпустила [Windows LAPS](#) (встроен в Windows 10/11 и Server 2019+), который использует другие атрибуты: `msLAPS-Password`, `msLAPS-PasswordExpirationTime` и `msLAPS-EncryptedPassword` (с поддержкой шифрования паролей в AD). При аудите проверяйте оба набора атрибутов - в реальных средах часто живут обе версии одновременно. По данным SentinelOne, контроль доступа к этим атрибутам - ключевой аспект безопасности LAPS.

Проверка покрытия LAPS - первое, что делает пентестер после получения доменной учётки:

Код:

```
# Компьютеры с ротацией LAPS (Legacy или Windows LAPS)
$withLAPS = Get-ADComputer -Filter * `
    -Properties ms-Mcs-AdmPwdExpirationTime, msLAPS-PasswordExpirationTime |
    Where-Object { $_.'ms-Mcs-AdmPwdExpirationTime' -ne $null -or `
        $_.'msLAPS-PasswordExpirationTime' -ne $null }
$all = Get-ADComputer -Filter *
Write-Host "LAPS: $($withLAPS.Count) / $($all.Count)"
# В средах с Windows LAPS (2023+) заполнен только msLAPS-*
```

Разница между числами - машины без LAPS. На практике вижу это регулярно: LAPS развёрнут на рабочих станциях, а серверы - файловые, серверы приложений, SQL-серверы - остались без покрытия. Угадайте, куда атакующий мигрирует в первую очередь? Туда, где один хеш локального администратора открывает всю серверную ферму.

Слабые пароли Active Directory через мiskonфигурацию LAPS

Даже при развёрнутом LAPS три мiskonфигурации делают его бесполезным. Эти риски описаны в исследовании SentinelOne по оценке уязвимостей LAPS.

Избыточные права на чтение ms-mcs-AdmPwd. По умолчанию пароль доступен только Domain Admins. Но администраторы часто делегируют права чтения сервисным учёткам или группам helpdesk - «чтобы ребята могли быстро заходить на машины». Атакующий перечисляет ACL на компьютерных объектах и находит учётки с правом «All Extended Rights» - этого достаточно для чтения пароля в открытом виде. Проверяйте делегирование командой Find-AdmPwdExtendedRights -Identity "OU=Workstations,DC=corp,DC=local" из модуля AdmPwd.PS - вывод покажет, кому конкретно делегированы права. В NetExec (преемник архивированного CrackMapExec) ещё проще: nxc ldap dc01 -u user -p pass -M laps - модуль перечислит все пароли, доступные текущей учётке.

Подмена AdmPwd.dll. LAPS использует клиентскую библиотеку c:\program files\LAPS\CSE\AdmPwd.dll для ротации паролей. Атакующий с локальным доступом может подменить DLL на модифицированную версию, перехватывающую пароли при каждой ротации. Защита - периодическая проверка хеша и подписи: Get-FileHash 'c:\program files\LAPS\CSE\AdmPwd.dll' и Get-AuthenticodeSignature 'c:\program files\LAPS\CSE\AdmPwd.dll'. Если подпись недействительна - DLL скомпрометирована.

Модификация searchFlags атрибута ms-mcs-AdmPwd. Значение searchFlags контролирует конфиденциальность атрибута. Флаг CONFIDENTIAL - бит 0x80 (128) в searchFlags. Атакующий с правами на схему может снять этот бит, убрав защиту, после чего любой аутентифицированный пользователь прочитает все пароли LAPS. Конкретное абсолютное значение searchFlags зависит от версии схемы, поэтому


```
проверяйте именно наличие бита 0x80: $sf = (Get-ADObject "CN=ms-Mcs-AdmPwd,CN=Schema,CN=Configuration,DC=corp,DC=local" -Properties searchFlags).searchFlags; if ($sf -band 128) { 'CONFIDENTIAL set' } else { 'CONFIDENTIAL missing!' }.
```

Рекомендация Microsoft - удалить право «All Extended Rights» с OU, содержащих компьютеры с LAPS: Active Directory Users and Computers → правый клик на OU → Properties → вкладка Security → Advanced → снять галочку «All Extended Rights» для ненужных групп.

Настройка логирования AD: что вы не видите в Windows Event Log

Критические Event ID для обнаружения lateral movement

Большинство компаний, которые я тестирую, имеют включённый базовый аудит - Event ID 4625 (неуспешный вход) и 4624 (успешный вход). Этого категорически мало: базовый аудит не покрывает Kerberoasting, AS-REP Roasting, DCSync и Pass-the-Ticket - основные техники пентестера после попадания в домен. По сути, вы смотрите в замочную скважину, когда атакующий заходит через окно.

Вот события, которые реально нужны для обнаружения атак на Active Directory:

 Часть контента скрыта. Этот материал доступен участникам сообщества с рангом [One Level или выше](#)

Получить доступ просто — достаточно проявить активность на форуме

AD базовая гигиена: пентест Active Directory за один рабочий день

Ниже - пошаговый чеклист, который покрывает три критических вектора за восемь часов. Приоритеты расставлены по критичности: сначала закрываем то, что атакующий эксплуатирует в первый час.

Часы 1-2: LLMNR и NBT-NS

1. Проверить состояние LLMNR на выборке хостов (запрос к реестру HKLM:\Software\Policies\Microsoft\Windows NT\DNSClient, ключ EnableMulticast).
2. Проверить состояние NBT-NS через `wmic nicconfig get caption,index,TcpipNetbiosOptions`.
3. Создать или обновить GPO: «Turn OFF Multicast Name Resolution» = Enabled.
4. Добавить PowerShell-скрипт отключения NBT-NS в Startup Scripts.
5. Протестировать: на хосте, получившем политику, запустить Responder в режиме анализа - хеши не должны прилетать.

Часы 3-4: LAPS

1. Посчитать покрытие LAPS: количество компьютеров с заполненным `ms-mcs-AdmPwdExpirationTime` относительно общего числа.
2. Проверить делегирование прав на чтение `ms-mcs-AdmPwd` через `Find-AdmPwdExtendedRights` по каждой OU.
3. Убедиться, что серверы покрыты LAPS, а не только рабочие станции.
4. Проверить параметры парольной политики LAPS в GPO: длина не менее 20 символов, максимальный срок действия не более 30 дней.
5. На выборке хостов проверить целостность `AdmPwd.dll` через `Get-AuthenticodeSignature`.

Часы 5-6: Аудит и логирование

1. На контроллере домена выполнить `auditpol /get /category:*` и зафиксировать текущее состояние.
2. Включить расширенный аудит Kerberos (Authentication Service, Service Ticket Operations) на Success и Failure.
3. Включить аудит Credential Validation для детекции NTLM-атак.
4. Включить аудит DS Access и DS Changes.
5. Настроить SACL на корневом объекте домена: добавить аудит-записи для Everyone на extended rights DS-Replication-Get-Changes (1131f6aa-9c07-11d1-f79f-00c04fc2dcd2) и DS-Replication-Get-Changes-All (1131f6ad-9c07-11d1-f79f-00c04fc2dcd2) - без этих конкретных GUID в SACL Event ID 4662 не зафиксирует DCSync. В SIEM исключайте события от компьютерных учёток DC\$ (легитимная репликация), чтобы не утонуть в ложных срабатываниях.

Часы 7-8: Верификация и документирование

1. Дождаться применения политик (`gpupdate /force` на контроллерах и выборке хостов).
2. Убедиться, что Event ID 4768 и 4769 появляются в Security Log контроллера домена при обычных аутентификациях.
3. Выполнить тестовый запрос TGS через `GetUserSPNs.py` из Impacket - проверить, что событие 4769 зафиксировано с корректными полями (имя учётки, запрошенный SPN, IP источника).
4. Задokumentировать все находки: что было, что изменили, что осталось.
5. Составить remediation-план с приоритетами для изменений, требующих change management.

Этот чеклист не заменяет полноценный пентест Active Directory - он закрывает три самых критичных вектора первого часа атаки. После его прохождения сеть перестает быть лёгкой добычей для Responder, lateral movement через одинаковые локальные пароли и необнаруженных DCSync-операций. Для глубокого аудита останутся проверки Kerberos-делегирования, ACL на объектах AD, привилегированных учётных

записей и доверительных отношений между доменами - но это задача на вторую неделю.

Вопрос к читателям

После отключения LLMNR через GPO часть легаси-приложений теряет связность - особенно те, которые обращаются к хостам по коротким именам без DNS-суффикса. У кого при установке «Turn OFF Multicast Name Resolution» в Enabled ломалось что-то на продуктиве, кроме самописных скриптов с хардкодом NetBIOS-имён? Какой DNS Suffix Search List в GPO по пути Computer Configuration > Administrative Templates > Network > DNS Client > DNS Suffix Search List решил проблему в вашей среде - один суффикс корневого домена или полный список с дочерними зонами? Покажите строку конфига - интересно сравнить подходы в средах с разным количеством доменов в лесу.

Последнее редактирование модератором: